Penetration Test Report

Security Assessment of Futurus

Guillermo Pamplona
guigapamplona@gmail.com

April 5, 2026

Contents

1. Engagement Overview **3**
- 1.1. Assessment Objectives . . . 3
- 1.2. Scope . . . 3
- 1.3. Threat Model and Assumptions . . . 3
- 1.4. Methodology . . . 3
- 1.5. Risk Rating Approach . . . 4
- 1.6. Limitations . . . 4

2. Executive Summary **5**
- 2.1. Assessment Outcome . . . 5
- 2.2. Key Findings at a Glance . . . 5
- 2.3. Business Impact . . . 6
- 2.4. Immediate Priorities . . . 6
- 2.5. Security Strengths . . . 6

3. Findings details **7**
- 3.1. HIGH Vulnerable JavaScript Library . . . 7
- 3.2. MEDIUM Information Disclosure . . . 13
- 3.3. INFO WHOIS Information Disclosure . . . 18

4. Remediation and Closure **20**
- 4.1. Assessment Artifacts and Cleanup . . . 20
- 4.2. Mitigation and Patching Guidance . . . 21
- 4.3. Retest Recommendation . . . 21
- 4.4. Confidential Information Handling . . . 21

A. Appendices **22**
- A.1. Summary of Passing Tests . . . 22

1. Engagement Overview

This report documents the results of the security assessment performed against the in-scope assets identified by the client. It is written to support both technical remediation and executive decision-making, with findings prioritized according to business risk and exploitability.

1.1. Assessment Objectives

The objectives of this engagement were to identify exploitable vulnerabilities, validate realistic attack paths, measure potential business impact, and provide practical remediation guidance. The assessment also evaluated whether weaknesses could expose sensitive data, enable unauthorized access, or reduce the confidentiality, integrity, or availability of business systems.

1.2. Scope

In-scope targets	https://futurus.com.br
Assessment window	02/04/26 to 5/04/26
Engagement type	External
Testing depth	Black box

1.3. Threat Model and Assumptions

The assessment assumed a motivated attacker with the level of access defined in the rules of engagement. This involved a black box penetration test, where no information besides the target domain was given.

1.4. Methodology

Testing should align with current industry practice and be tailored to the engagement type. A typical workflow includes:

1. Reconnaissance and asset validation.
2. Enumeration of services, technologies, trust relationships, and attack surface.
3. Vulnerability identification through manual testing and focused tooling.

4. Exploitation to confirm impact while remaining within agreed safety limits.
5. Post-exploitation validation, privilege analysis, and lateral movement assessment where authorized.
6. Documentation of evidence, affected assets, and remediation guidance.

1.5. Risk Rating Approach

Each finding in this report includes a CVSS v3.1 base score to provide a consistent technical severity rating. Final remediation priority should also consider business context, asset criticality, data sensitivity, exploit maturity, exposure, and the availability of compensating controls.

1.6. Limitations

This report reflects the state of the assessed environment during the testing window only. Security posture may change as systems are patched, configurations are modified, assets are added or removed, or new vulnerabilities become publicly known after the assessment date.

2. Executive Summary

The penetration test evaluated Futurus external security posture from an external network penetration test from April 2th, 2026 to APril 5th, 2026. The tests were performed from a black box perspective, simulating a realistic scenario. After performing the assessment, a vulnerability with a high severity score was found, which could lead to a denial of service attack. It is highly advised that Futurus addresses these vulnerabilities as soon as possible, given the fact that these vulnerabilities are easily found through basic reconnaissance and have low exploitation complexity.

2.1. Assessment Outcome

The penetration test revealed several security issues primarily related to vulnerable JavaScript libraries and information disclosure. These findings did not result in a system compromise or direct takeover of an account, but an attacker with access to this information could leverage further exploits.

Considering the results, the application demonstrates a moderate security posture. During the assessment, no immediate exploit paths were found to gain further access or takeover an account.

2.2. Key Findings at a Glance

HIGH **Vulnerable JavaScript Library** **8.2**

`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:H`
The jQuery Validation Plugin version used (v1.14.0) is vulnerable to Cross Site Scripting (XSS) and Regular Expression Denial of Service (ReDos).

MEDIUM **Information Disclosure** **5.3**

`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N`
An attacker can bruteforce names and phone numbers of users registered in the website.

INFO **WHOIS Information Disclosure** **0**

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:N
WHOIS records reveal identifiable information such as the owners name, country and email.

2.3. Business Impact

The assessment identified multiple security weaknesses, mainly related to vulnerable JavaScript libraries, and information disclosure, through which, the attacker could find potential targets. Even though full system compromise or account takeover were not achieved during testing, these issues reflect weaknesses in application configuration and access control.

Overall, the application presents a moderate security posture with some areas requiring remediation.

2.4. Immediate Priorities

- High-severity findings that could enable direct compromise or data exposure.
- Validate fixes through targeted retesting before closing the engagement.

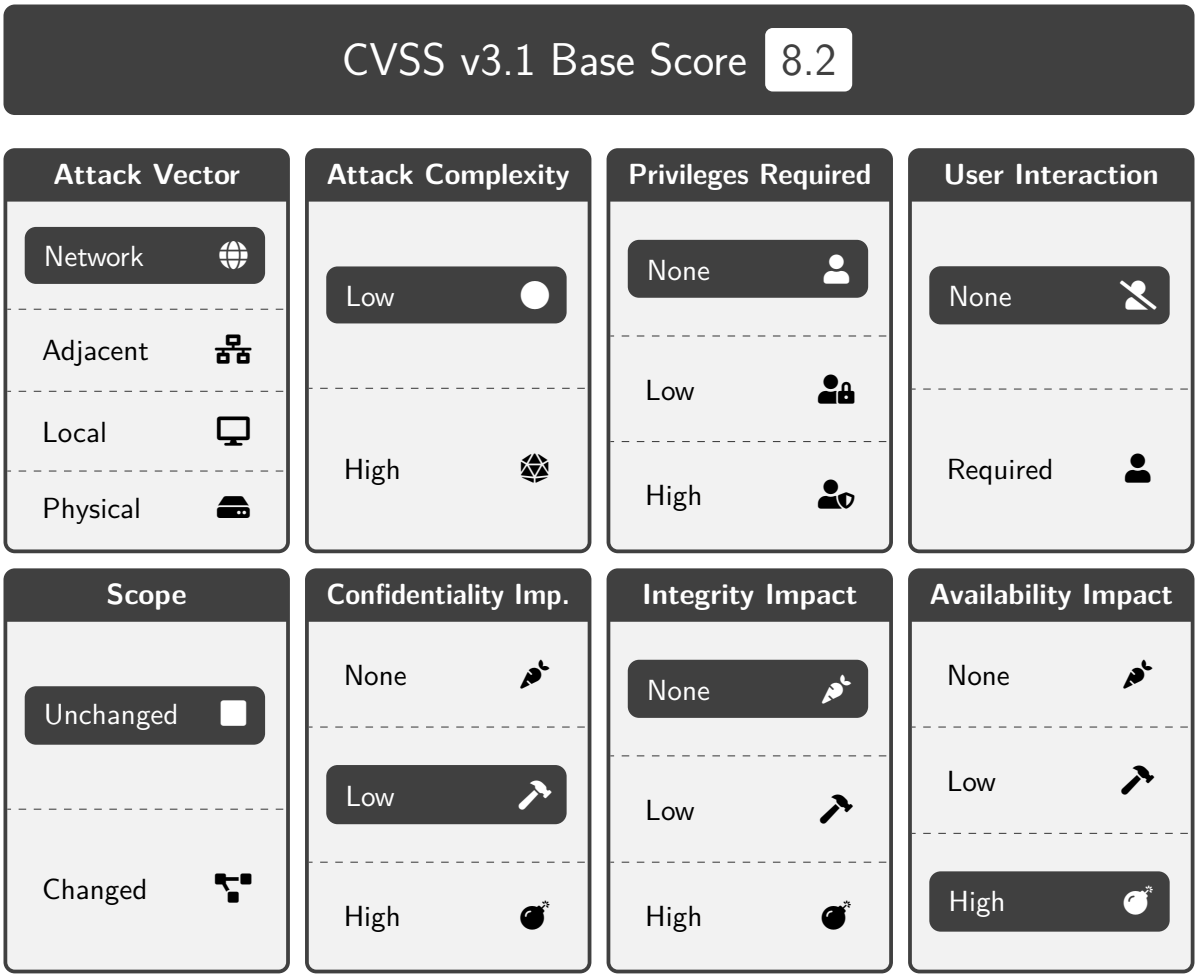
2.5. Security Strengths

During the engagement, the application demonstrated a resilient security posture against several critical vulnerability categories. The core infrastructure and application logic successfully withstood targeted testing in the following areas (a complete summary is available in A.1):

- Robust Access Controls: The application effectively enforces authorization boundaries. Attempts to access the administrative portal without proper credentials were successfully blocked, and strict data boundaries are maintained between individual users, preventing unauthorized access to cross-user data (such as support tickets).
- Strong Input Validation: Core functionalities, including data entry fields and file upload mechanisms, properly sanitize and validate user input. This robust handling successfully prevented attempts to execute Cross-Site Scripting (XSS) and SQL Injection (SQLi) attacks.
- Secure Configuration & Asset Management: The server configuration adheres to security best practices by actively restricting access to sensitive directories, disabling directory listing, and properly securing session tokens (cookies). This significantly minimizes the application's exposed attack surface.

3. Findings details

3.1. HIGH Vulnerable JavaScript Library



Summary The jQuery Validation Plugin version used (v1.14.0) is vulnerable to Cross Site Scripting (XSS) and Regular Expression Denial of Service (ReDos).

Impact If the attacker can input code into a dynamic error message field, the attacker could run JavaScript code. If the attacker finds a form field that uses url2 validation, a specially crafted url string could be used to perform a Denial of Service attack.

Proof of concept Use OWASP ZAP in order to crawl the website and look for general vulnerabilities.

- Define the scope:

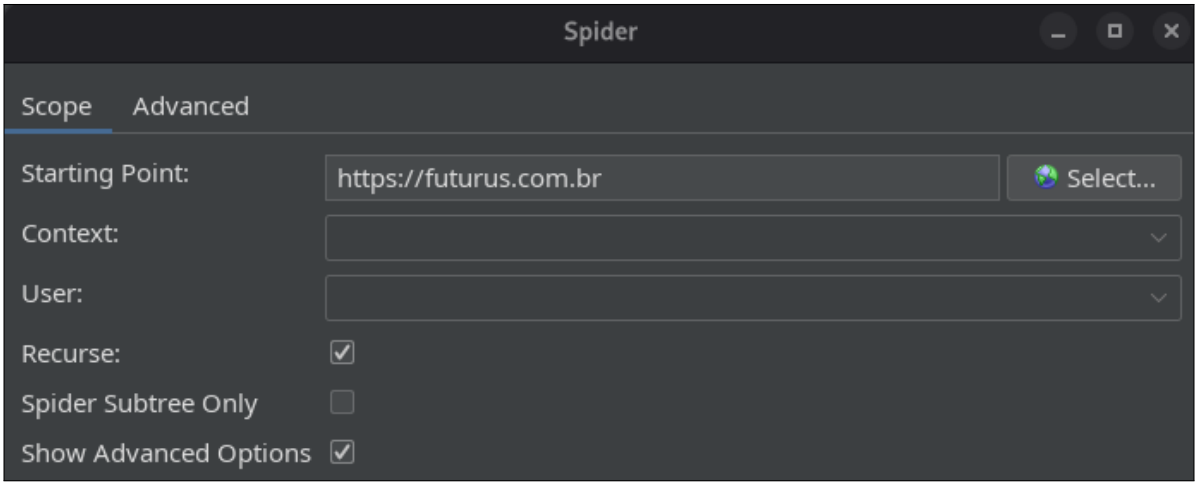


Figure 3.1.: Scope of the spider

- Set the following advanced settings:

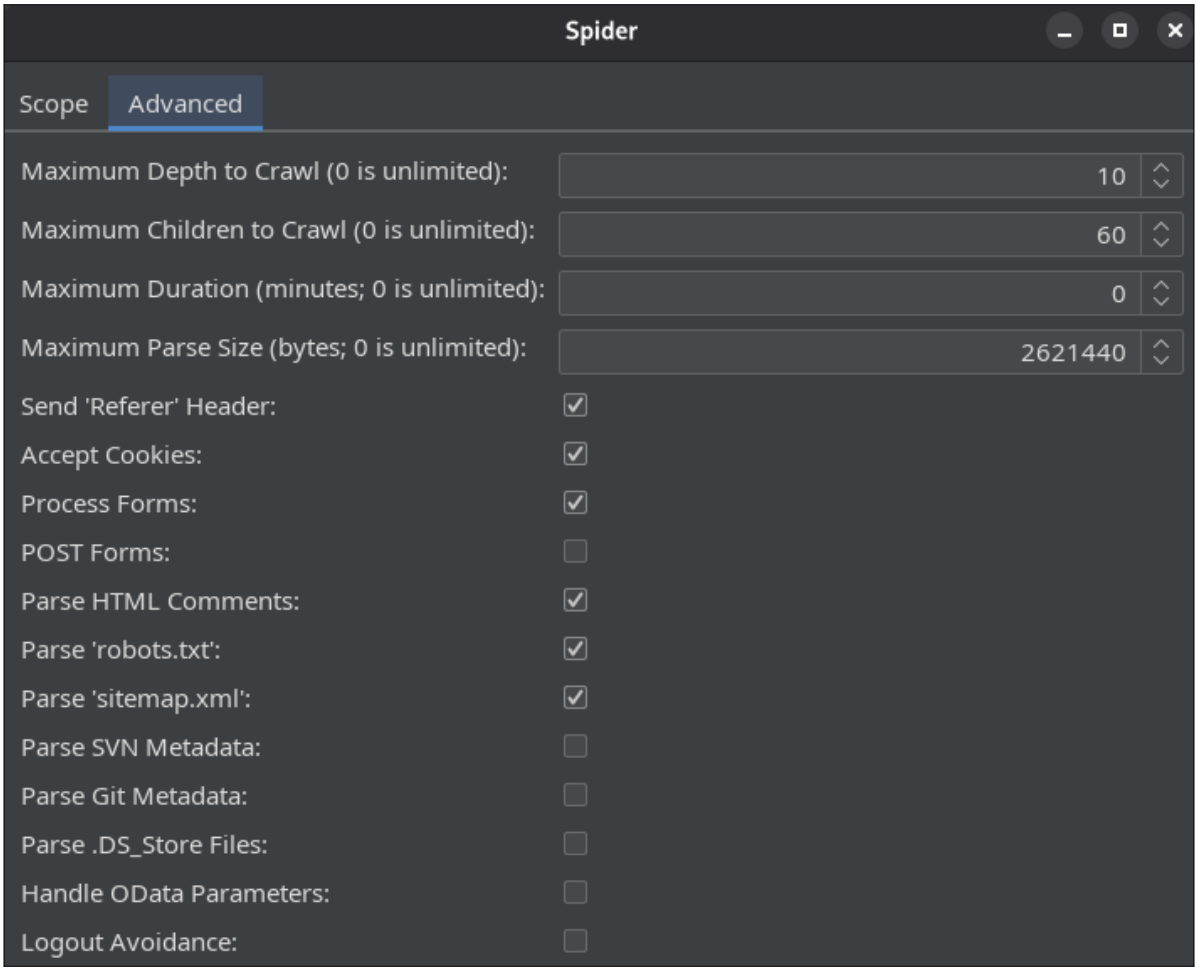


Figure 3.2.: Advanced settings to configure the spider

- Look the information gathered by the spider:

Figure 3.3.: Alerts triggered by the spider

- Look at the validation.js file under https://futurus.com.br/assets/templates/basic/js/validation.js:

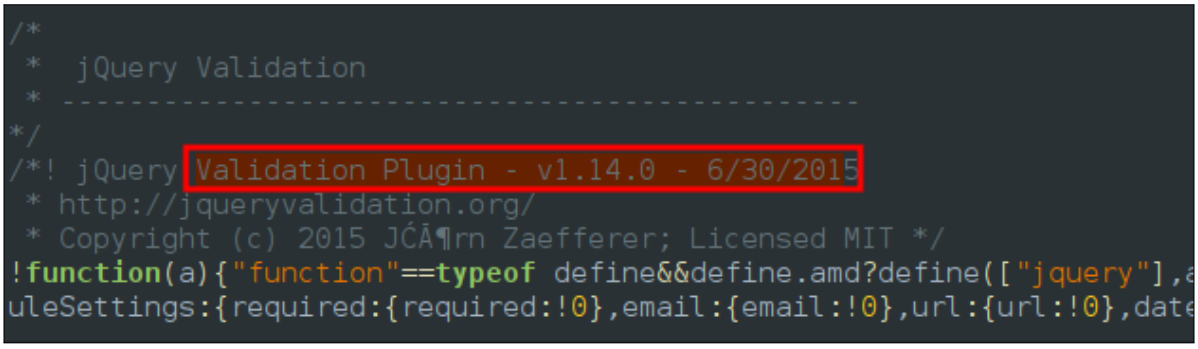


Figure 3.4.: jQuery Validation file

- Check the summary generated by OWASP ZAP:

Vulnerable JS Library

URL: https://futurus.com.br/assets/templates/basic/js/validation.js
Risk: High
Confidence: Medium
Parameter:
Attack:
Evidence: /*! jQuery Validation Plugin - v1.14.0
CWE ID: 1395
WASC ID:
Source: Passive (10003 - Vulnerable JS Library (Powered by Retire.js))
Input Vector:

Description:

The identified library appears to be vulnerable.

Other Info:

The identified library jquery-validation, version 1.14.0 is vulnerable.
CVE-2022-31147
CVE-2021-21252

Figure 3.5.: Summary of the vulnerability

Observed evidence We tested for XSS vulnerability, but couldn't find a dynamic error message to input the exploit. The ReDos vulnerability wasn't tested availability concerns.

Recommendations

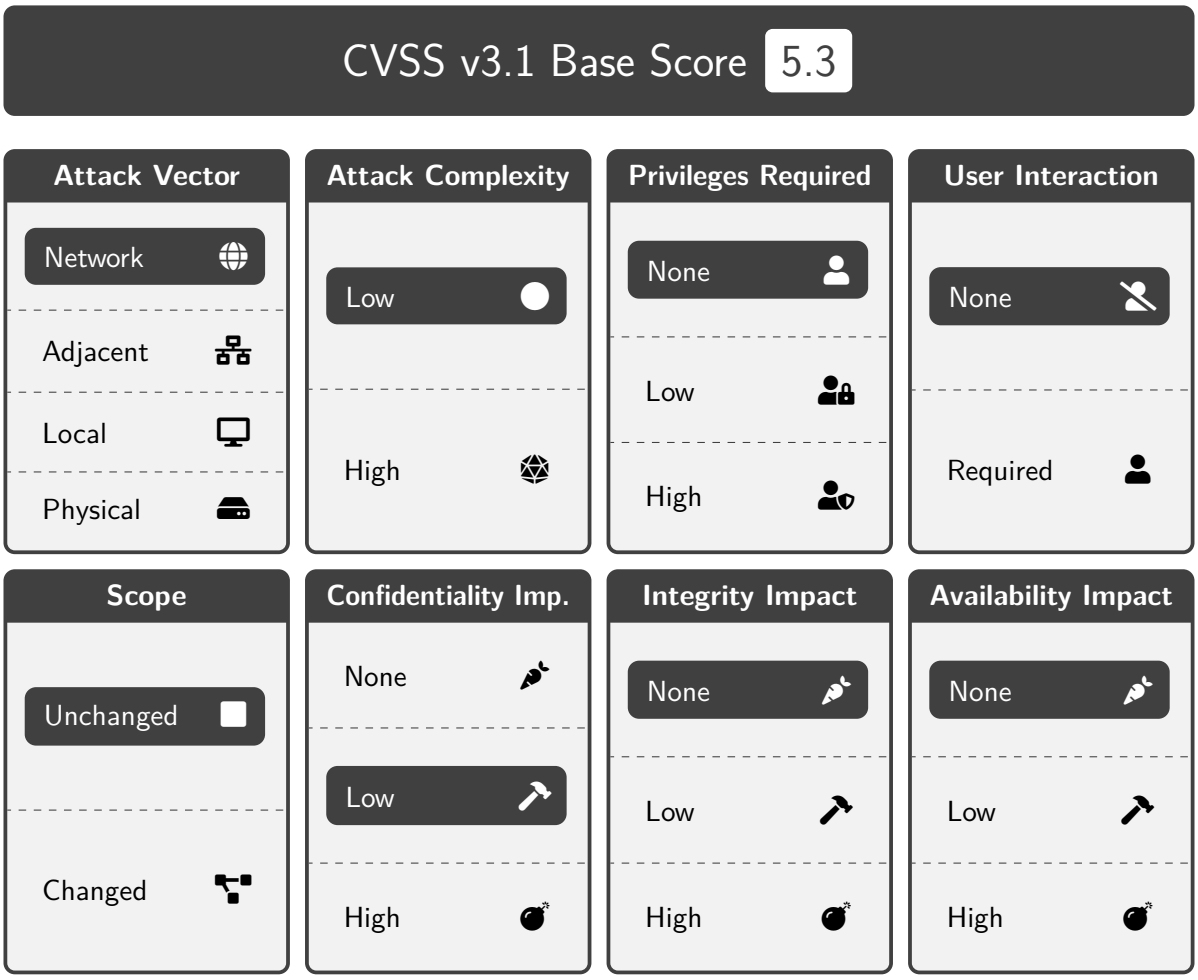
- Upgrade the library to the latest version.
- Remove unused dependencies, unnecessary features, components, etc.
- Monitor for libraries and components that are unmaintained or don't have security patches for older versions.

References

- CWE MITRE definition
- OWASP Vulnerable and Outdated Component

- ReDos CVE-2021-21252
- XSS CVE-2025-3574

3.2. MEDIUM Information Disclosure



Summary An attacker can bruteforce names and phone numbers of users registered in the website.

Impact Gives the attacker the ability to potentially gather usernames and numbers of potential targets, and perform further exploits or phishing campaigns.

Proof of concept

- First, we need to register a new account:

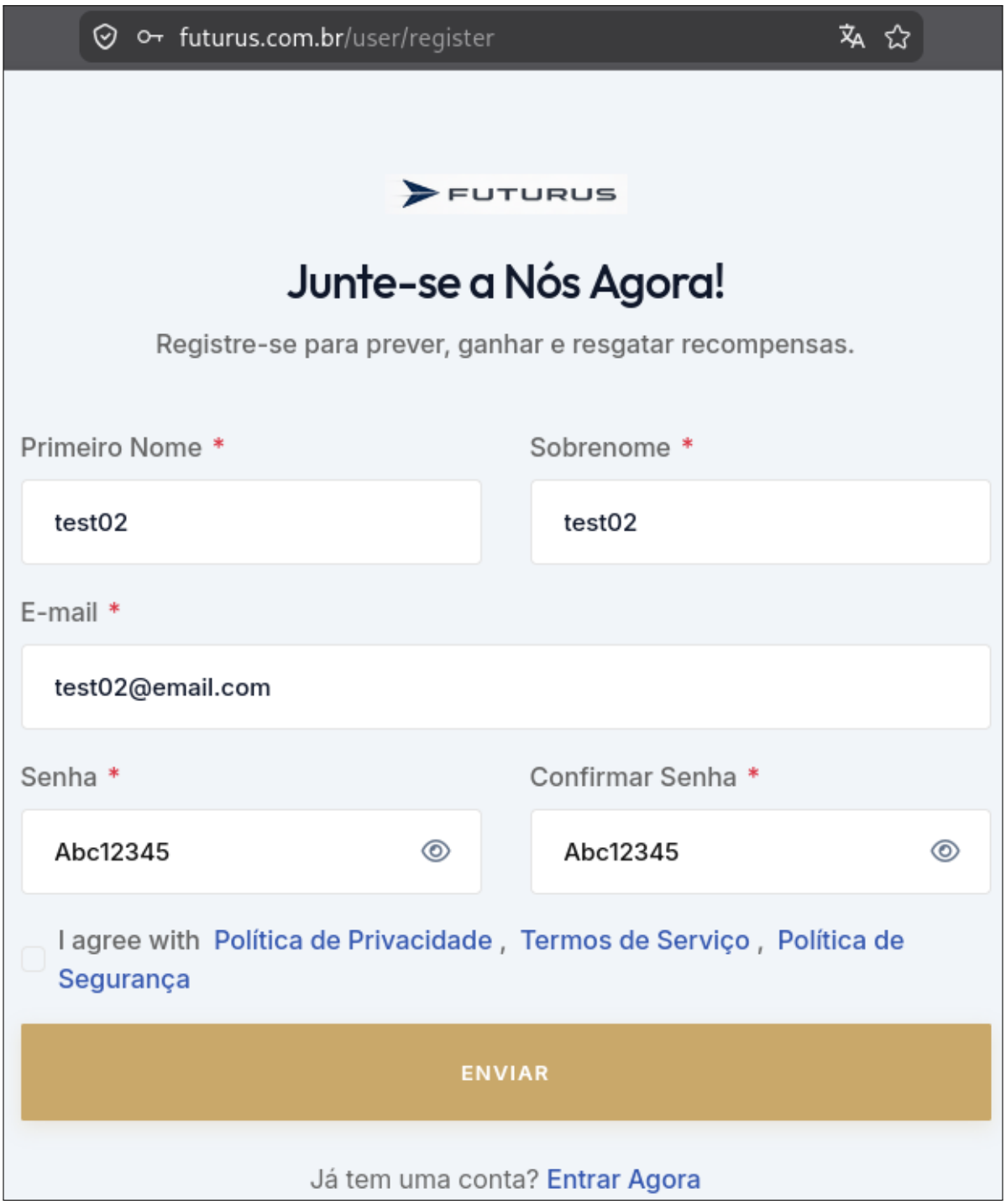


Figure 3.6.: Form for registering a new user

- Next, we will be redirected to fill more information about the user:

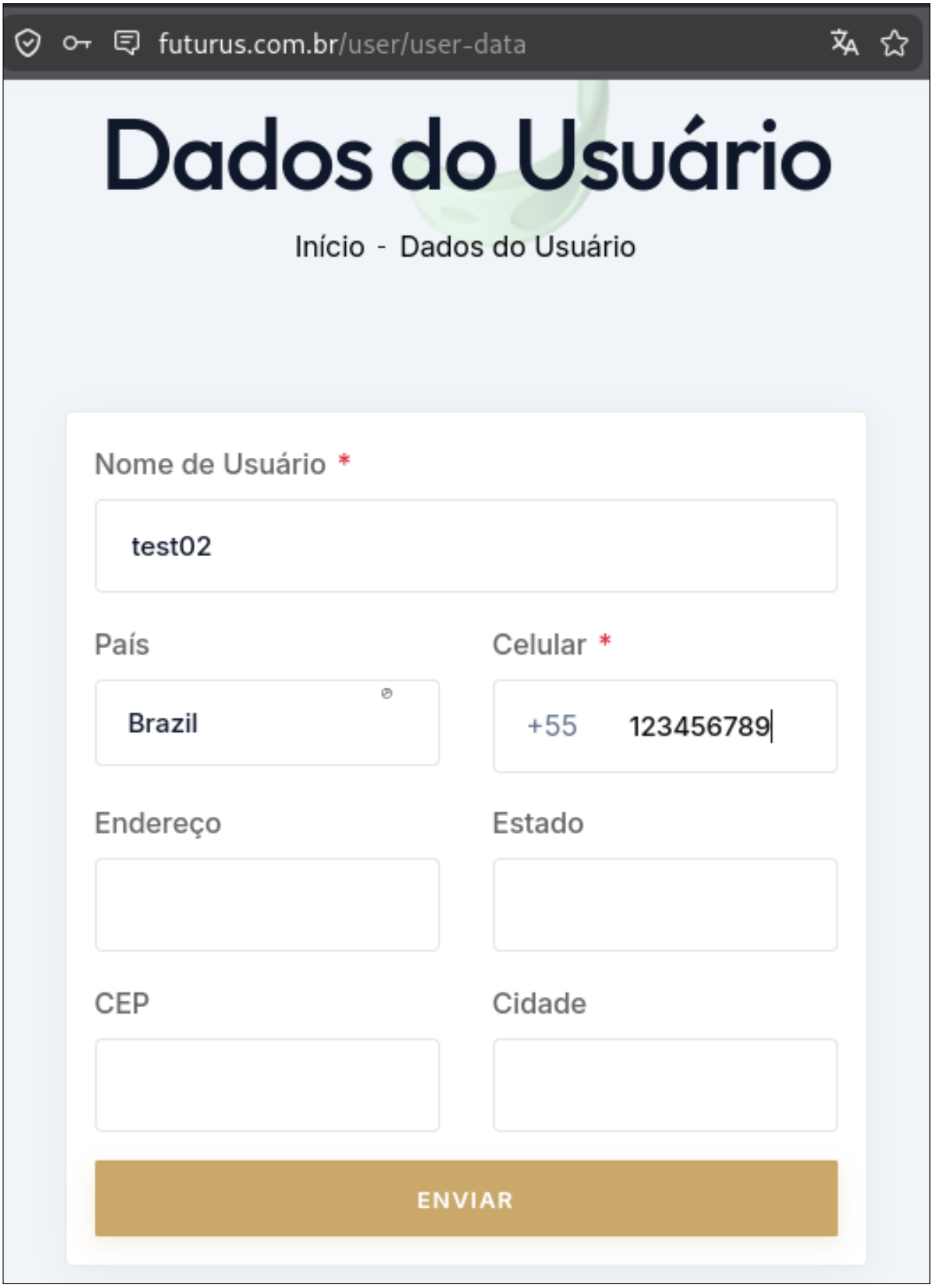


Figure 3.7.: Form for adding additional information after registration

- We can change the values of the password and phone number individually, and it will notify if there is already a user with the data on each field:

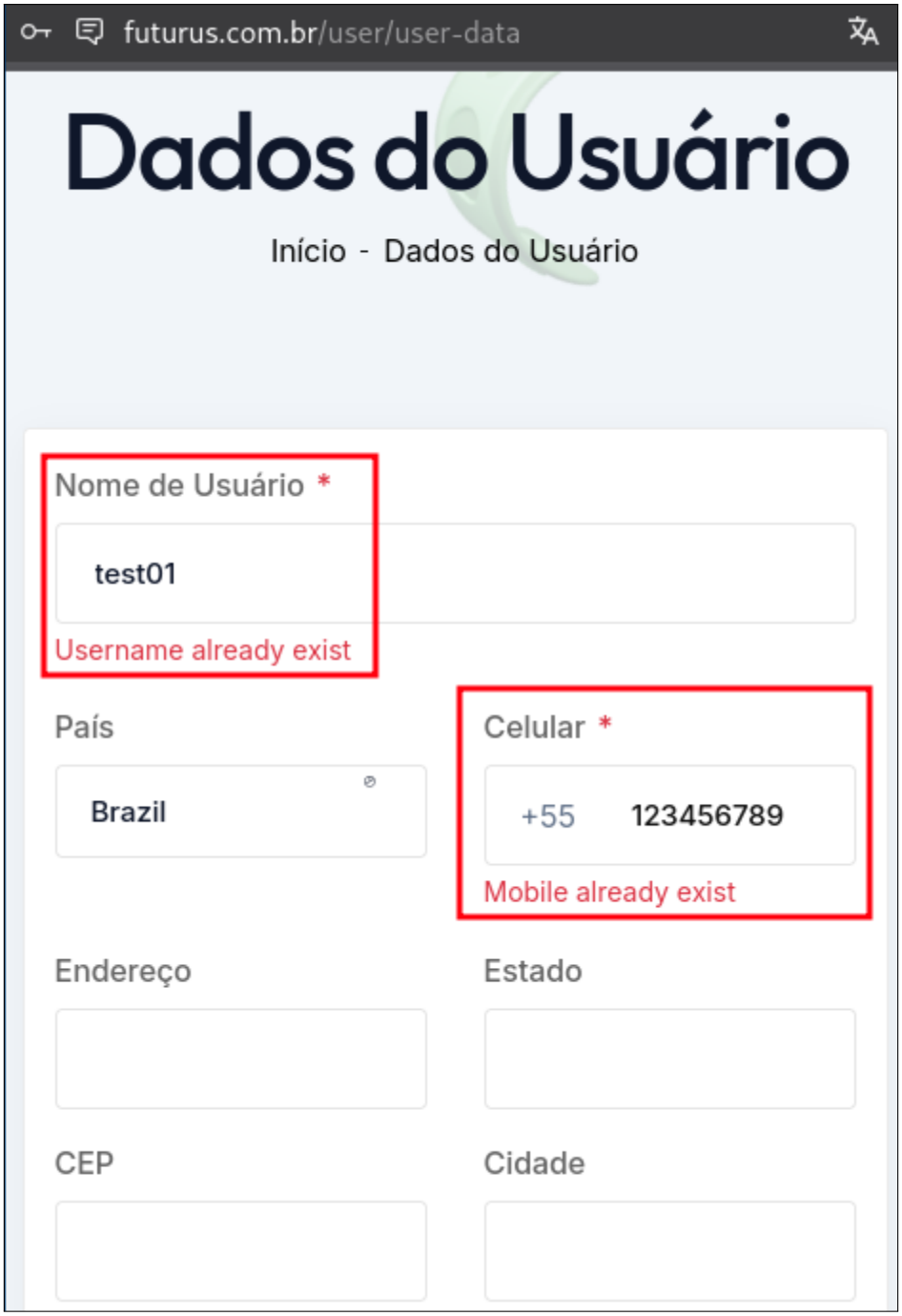


Figure 3.8.: Form for adding additional information after registration

Observed evidence This data was gathered using dummy accounts.

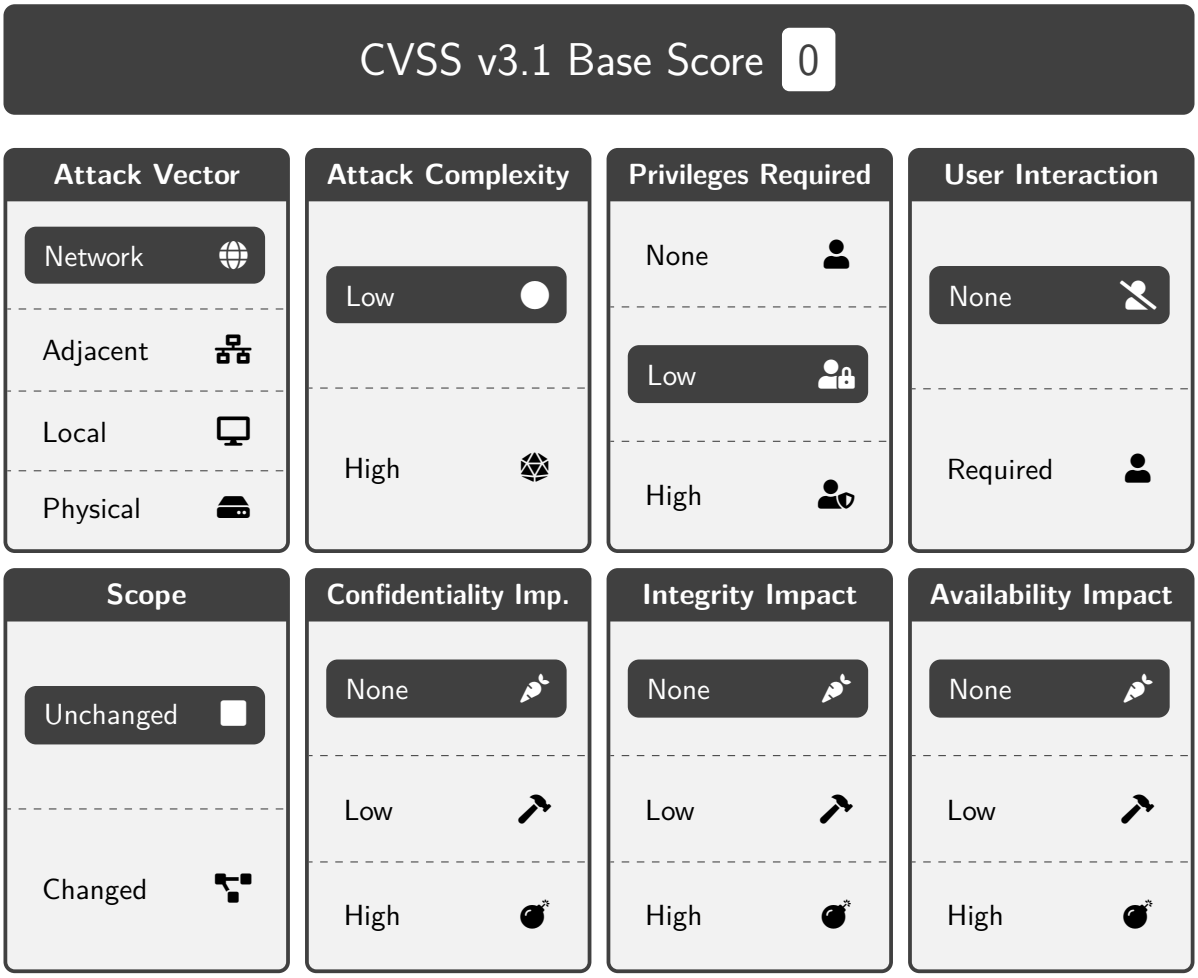
Recommendations

- When testing for usernames and other potentially sensitive fields, limit the number of checks allowed per user.
- Restrict the volume of requests allowed from a single IP address to detect and block automated enumeration tools.

References

- CWE MITRE definition

3.3. INFO WHOIS Information Disclosure



Summary WHOIS records reveal identifiable information such as the owners name, country and email.

Impact With the exposed information about the owner, an attacker could perform phishing campaigns and social engineering attacks.

Proof of concept

- Found the following information from WHOIS:

```
┌──(gpuser㉿gp)-[~/data/temp_files]
└─$ whois futurus.com.br
% Copyright (c) Nic.br - Use of this data is governed by the Use and
% Privacy Policy at https://registro.br/upp . Distribution,
% commercialization, reproduction, and use for advertising or similar
% purposes are expressly prohibited.
% 2026-04-05T23:27:22-03:00

domain:      futurus.com.br
owner:       marcelo anjos
ownerid:     ***.118.878-**
country:     BR
owner-c:     MAANJ117
tech-c:      MAANJ117
nserver:     elinore.ns.cloudflare.com
nsstat:      20260401 AA
nslastaa:    20260401
nserver:     finley.ns.cloudflare.com
nsstat:      20260401 AA
nslastaa:    20260401
saci:        yes
created:     20210916 #23402914
changed:     20260227
expires:     20260916
status:      published

nic-hdl-br:  MAANJ117
person:      marcelo anjos
e-mail:      projetoslinux@gmail.com
country:     BR
created:     20260224
changed:     20260227
```

Figure 3.9.: WHOIS information regarding the domain futurus.com.br

Observed evidence The data was gathered during the penetration test.

Recommendations

- Use domain privacy services.

References

- CWE MITRE definition

4. Remediation and Closure

4.1. Assessment Artifacts and Cleanup

Username	test01 and test02.
Ticket id	

- CT3A5JOKTKXI
- CB2ZFX1VRNNS
- MWHEOT0LG4CW
- YFOESYCELKM0
- W6MEBCPYJRFP
- QKEKF3DSRDNM
- 5MOZAZIYUOVH
- 8JR6PKCD3BIW
- OLJCR1BHXZLP
- S6WOHVPSTCNL
- VW9ZWQKA8DMW
- 3SGN7A4P9GYK
- BZ2D4PXKS9M3
- EUHCP4LP3ORI
- NNBMLUK1CP17
- TC3PXLAVDPPV
- PIFNY1YDHKWB
- 5SKSHCG3BR0I
- AHEWMH7XTI7J

4.2. Mitigation and Patching Guidance

Remediation should prioritize issues that enable denial of service or direct data exposure. For each finding, the final report states the recommended fix, and displays a note about the vulnerability via the observed evidence field.

Priority 1	Patch or reconfigure critical and high findings with confirmed exploit paths.
Priority 2	Add regression tests, secure configuration baselines, and review processes to prevent recurrence.

4.3. Retest Recommendation

After remediation is complete, conduct a focused retest to verify that the reported weaknesses are no longer exploitable and that no regressions or compensating-control gaps remain.

4.4. Confidential Information Handling

Confidential Data Handling Assurance

All credentials, exports, screenshots, packet captures, and other confidential client data collected during the engagement must be securely deleted from analyst workstations, collaboration tools, and backups after report acceptance, except where a written retention requirement has been agreed with the client.

A. Appendices

A.1. Summary of Passing Tests

Vulnerability Category	Testing Scope & Execution	Status
Broken Access Control (IDOR)	Attempted unauthorized access to administrative interfaces and cross-user data (support tickets).	Tested - Pass
Injection (SQLi)	Evaluated database interactions and input parameters against standard injection payloads.	Tested - Pass
Cross-Site Scripting (XSS)	Assessed multiple input vectors and data entry fields for stored and reflected script execution.	Tested - Pass
Insecure File Upload	Tested upload mechanisms with malicious payloads to bypass file-type restrictions.	Tested - Pass
Security Misconfiguration	Scanned for directory indexing, unauthorized access to configuration files, and insecure cookie storage.	Tested - Pass

Table A.1.: Security Controls & Negative Findings Matrix